

**TEMPLATE
PROJECT WORK**

Corso di Studio	INFORMATICA PER LE AZIENDE DIGITALI (L-31)
Dimensione dell'elaborato	Minimo 6.000 – Massimo 10.000 parole <i>(pari a circa Minimo 12 – Massimo 20 pagine)</i>
Formato del file da caricare in piattaforma	PDF
Nome e Cognome	Francesco Ferrantini
Numero di matricola	0312402165
Tema n. (Indicare il numero del tema scelto):	2
Titolo del tema (Indicare il titolo del tema scelto):	Privacy e sicurezza aziendale
Traccia del PW n. (Indicare il numero della traccia scelta):	13
Titolo della traccia (Indicare il titolo della traccia scelta):	Sviluppo di un software mobile-friendly per il calcolo del fattore di rischio
Titolo dell'elaborato (Attribuire un titolo al proprio elaborato progettuale):	Come valutare correttamente il fattore di rischio informatico: metodologia, normativa e best practice

PARTE PRIMA – DESCRIZIONE DEL PROCESSO

Utilizzo delle conoscenze e abilità derivate dal percorso di studio

(Descrivere quali conoscenze e abilità apprese durante il percorso di studio sono state utilizzate per la redazione dell'elaborato, facendo eventualmente riferimento agli insegnamenti che hanno contribuito a maturarle):

Per questo elaborato ho attinto a diversi insegnamenti del percorso L-31, in particolare quelli legati alla sicurezza informatica, ai sistemi di elaborazione delle informazioni e al disegno e metodi dell'ingegneria del software. A questo si è aggiunta l'esperienza lavorativa in un'azienda informatica, che mi ha permesso di collegare temi e tecnologie diverse, un contributo che si è rivelato utile nella stesura e nella compilazione di quanto sviluppato in questo PW.

Dal lato della sicurezza informatica e della normativa sulla protezione dei dati vengono i concetti di valutazione del rischio (risk assessment), insieme ai riferimenti al Regolamento (UE) 2016/679 (GDPR) e alla Direttiva NIS2, oltre alla logica dei framework internazionali ISO/IEC 27001-27005 e NIST SP 800-30: è su queste basi che ho ricavato la formula del fattore di rischio e la relativa matrice di criticità. Gli insegnamenti di programmazione ed elaborazione delle informazioni, invece, mi hanno dato gli strumenti tecnici per sviluppare la pagina web (HTML, CSS, JavaScript).

Non meno importanti sono state le competenze trasversali: analisi, problem solving, capacità di organizzare le informazioni, senza le quali sarebbe stato difficile costruire esempi applicativi realistici e tradurre concetti teorici di gestione del rischio in casi pratici comprensibili.

Quello che ritengo più rilevante, però, è aver dovuto tenere insieme ambiti molto diversi tra loro: quello normativo, che ha fornito la cornice di riferimento; quello metodologico, che mi ha permesso di impostare e affrontare il problema e quello tecnico-informatico, con cui ho sviluppato e affinato il progetto vero e proprio. Tenerli insieme in un unico elaborato coerente non è stato scontato, ma

conferma, per quella che è la mia seppur modesta esperienza in questo ambito, come i diversi compartimenti di applicazione e conoscenza non siano mai separati: si intrecciano sempre tra loro per ottenere un risultato migliore.

Fasi di lavoro e relativi tempi di implementazione per la predisposizione dell'elaborato
(Descrivere le attività svolte in corrispondenza di ciascuna fase di redazione dell'elaborato. Indicare il tempo dedicato alla realizzazione di ciascuna fase, le difficoltà incontrate e come sono state superate):

Ho organizzato il lavoro in fasi successive con la loro relativa durata (indicativa) per svolgere questo project work, ho optato per un'analisi top-down andando a scomporre un po' alla volta quella che era la richiesta relativa alla realizzazione del index.html e durante la stesura e ricerca degli argomenti teorici affrontati.

- **Fase 1 - Analisi della traccia (1 giorno):** lettura approfondita della traccia PW13, identificazione degli elaborati richiesti e dei relativi criteri di valutazione, definizione del piano di lavoro.
- **Fase 2 - Studio normativo e metodologico (2 giorni):** studio di GDPR, NIS2, ISO/IEC 27001-27005 e NIST SP 800-30; scelta della formula $R = P \times I$ e della scala di riferimento a 5 livelli come base metodologica, invece di una formula inventata, per rendere il lavoro difendibile.
- **Fase 3 - Progettazione dei contenuti della guida (3 giorni):** definizione dei contenuti teorici della guida, differenza tra probabilità e impatto, ruolo delle CVE (Common Vulnerabilities and Exposures), categorizzazione dei rischi, con particolare attenzione a strutturarli come percorso didattico e non come semplice elenco di definizioni normative slegate tra loro e verifica attiva di cosa sia effettivamente necessario durante un processo di valutazione del rischio.
- **Fase 4 - Sviluppo della struttura della pagina web (4 giorni):** realizzazione della struttura HTML e del foglio di stile CSS della pagina web. La parte più delicata è stata calibrare le regole responsive per la resa mobile, verificando più volte il comportamento del layout sotto i 620px di larghezza e correggendo in particolare la sovrapposizione di alcuni elementi testuali oltre che la gestione delle variabili e delle funzioni, continuo debugging del codice.
- **Fase 5 – (Aggiornamento) Calcolatore interattivo e QR code (2.5 giorni):** implementazione di alcune feature nel file index.html come, ad esempio, quella del calcolatore interattivo e integrazione del QR code (parte fondamentale e richiesta). Importante era far corrispondere esattamente la logica del codice alla stessa formula descritta nella parte teorica, evitando disallineamenti tra ciò che il documento spiega e ciò che il codice effettivamente calcola, svolte attività di controllo e miglioramento del codice madre.
- **Fase 6 - Esempi applicativi e best practice (2 giorni):** analisi degli scenari “tipo” in un ambiente lavorativo e identificazione dei campi a cui prestare maggiore attenzione; costruzione dei quattro esempi di rischio prima/dopo mitigazione e redazione delle best practice di sicurezza, verificando che ogni esempio fosse coerente con i concetti teorici esposti in precedenza.
- **Fase 7 - Test, revisione e documentazione finale (3 giorni):** test funzionali, responsive e di accessibilità sulla pagina web; revisione complessiva dei contenuti; compilazione finale del template e della bibliografia.

Risorse e strumenti impiegati

(Descrivere quali risorse - bibliografia, banche dati, ecc. - e strumenti - software, modelli teorici, ecc. - sono stati individuati ed utilizzati per la redazione dell'elaborato. Descrivere, inoltre, i motivi che hanno orientato la scelta delle risorse e degli strumenti, la modalità di individuazione e reperimento delle risorse e degli strumenti, le eventuali difficoltà affrontate nell'individuazione e nell'utilizzo di risorse e strumenti ed il modo in cui sono state superate):

Per la redazione dell'elaborato ho fatto riferimento sia a risorse bibliografiche e normative sia a strumenti software, scelti in base a criteri di affidabilità, gratuità e assenza di dipendenze complesse, trattandosi di un progetto didattico.

Strumenti software e librerie:

- **HTML5 / CSS3 / JavaScript (ES6)** - struttura, stile (CSS) e logica interattiva (JavaScript) della pagina web, tutto in un unico file autonomo, senza framework esterni
- **Python - qrcode** - libreria Python usata come strumento di supporto offline per produrre l'immagine del QR code, poi incorporata nella pagina

Una precisazione importante sulla pagina web: dopo una prima bozza in cui CSS e generazione del QR code erano trattati come componenti separate, ho consolidato tutto in un unico file index.html autonomo, spostando anche il calcolo del fattore di rischio lato client in JavaScript (paragrafo 3.5), invece di lasciarlo descritto solo in uno script Python esterno alla pagina. Questa scelta rende il file effettivamente autosufficiente: può essere aperto direttamente in un browser, anche senza connessione a internet e senza altri file di supporto.

La scelta di una libreria Python open source per generare il QR code offline, invece di un servizio online, è stata motivata dalla volontà di mantenere il controllo completo sul processo, evitare dipendenze da servizi di terze parti (rilevante anche in ottica di sicurezza, essendo questo un progetto sul tema della sicurezza informatica) e poter documentare il passaggio con codice sorgente ispezionabile.

Repository del codice sorgente

Il codice sorgente del progetto è pubblicato sul seguente repository pubblico GitHub:

<https://github.com/franzferra/Unipegaso-PW13/tree/main>

questo invece è il link della pagina web finale:

<https://franzferra.github.io/Unipegaso-PW13/>

Il repository contiene i seguenti file:

- **index.html** - pagina web completa e autonoma (HTML, CSS e JavaScript in un unico file)
- **fattore_rischio_informatico.pdf** - quello che dovrebbe essere il pdf contenente le indicazioni e tutto ciò che può aiutare l'utente finale a calcolare il fattore di rischio, nel nostro caso è una copia pdf del template stesso.

Bibliografia e sitografia:

Normative e standard:

- **Parlamento europeo e Consiglio dell'Unione Europea. Regolamento (UE) 2016/679 (GDPR).** - Regolamento generale sulla protezione dei dati, Gazzetta Ufficiale dell'Unione Europea, 2016
- **Parlamento europeo e Consiglio dell'Unione Europea. Direttiva (UE) 2022/2555 (NIS2).** - misure per un livello comune elevato di cibersecurity nell'Unione, Gazzetta Ufficiale dell'Unione Europea, 2022
- **ISO/IEC. ISO/IEC 27001:2022.** - Information security, cybersecurity and privacy protection - Information security management systems - Requirements, 2022
- **ISO/IEC. ISO/IEC 27005:2022.** - Information security, cybersecurity and privacy protection - Guidance on managing information security risks, 2022

- **NIST. Special Publication 800-30 Revision 1.** - Guide for Conducting Risk Assessments, National Institute of Standards and Technology, 2012
- **NIST. National Vulnerability Database (NVD).** - database pubblico delle vulnerabilità note (CVE) e dei relativi punteggi di gravità CVSS. Consultato nel 2026. nvd.nist.gov
- **MITRE Corporation. CVE Program.** - programma di catalogazione delle vulnerabilità software note (Common Vulnerabilities and Exposures). Consultato nel 2026. cve.org

Documentazione tecnica:

- **MDN Web Docs.** - documentazione ufficiale HTML, CSS, JavaScript. Consultato nel 2026.

[Developer.mozilla.org](https://developer.mozilla.org)

Sitografia di articoli utili per il mio lavoro:

- **Cyber Security 360 - Sicurezza informatica, IT Security e Cyber Crime**
- **Red Hot Cyber - Cybersecurity, Cybercrime e Intelligenza Artificiale**
- **agendadigitale.eu**

Documentazione universitaria:

- **Dispense** - ho usufruito delle dispense messe a disposizione dalla piattaforma per quelle materie e argomenti che ho ripreso e riportato nel project work.

Per lo sviluppo di questo project work ho utilizzato l'AI come support di debugging durante la fase di programmazione, per l'implementazione delle tecnologie come quella del qr code e per la creazione di alcune immagini che ho inserito all'interno di questo template.

PARTE SECONDA – PREDISPOSIZIONE DELL'ELABORATO

Obiettivi del progetto

(Descrivere gli obiettivi raggiunti dall'elaborato, indicando in che modo esso risponde a quanto richiesto dalla traccia):

Gli obiettivi indicati dalla traccia sono stati affrontati nell'elaborato seguendo un percorso preciso. Per quanto riguarda l'analisi di normative e procedure di valutazione del rischio, ho studiato le normative di riferimento (GDPR, NIS2) insieme agli standard internazionali di gestione del rischio (ISO 27001, ISO 27005, NIST SP 800-30), individuando in essi il modello $R = P \times I$ adottato in questo elaborato poichè rappresenta l'approccio più diffuso nella valutazione del rischio. Per la progettazione e redazione del documento esplicativo, ho scritto una guida chiara e dettagliata (paragrafi 3.1-3.6 di questo documento) che illustra formule, scale di valutazione, il ruolo delle vulnerabilità note (CVE), la logica di mitigazione del rischio e le best practice di settore, o quindi cercato di affiancare a ogni parte degli esempi applicativi oltre che i puri riferimenti normativi.

Per quanto riguarda la creazione della pagina HTML per il download, ho sviluppato una pagina in HTML, CSS e JavaScript con link diretto al PDF che viene conservato sulla repository di github in modo da usare un link statico gratuito privo da dipendenze di provider, curando in particolare la chiarezza e l'intuitività dei contenuti: gerarchia visiva, pulsanti di azione ben visibili e descrizioni dei livelli sempre disponibili all'utente.

Infine, per integrare una versione mobile friendly con QR code, ho progettato la pagina secondo un approccio mobile first negli aspetti più critici (pulsanti a piena larghezza, layout a colonna singola sotto i 620px) e ho incluso un QR code generato appositamente per l'accesso rapido da smartphone.

Ritengo quindi che tutti gli obiettivi indicati dalla traccia siano stati raggiunti; nel paragrafo "Valutazione dei risultati" discuto anche i limiti riscontrati.

Contestualizzazione

(Descrivere il contesto teorico e quello applicativo dell'elaborato realizzato):

Il tema scelto dalla traccia (Tema 2 - Privacy e sicurezza aziendale) si inserisce in un momento normativo particolarmente attuale e delicato per le aziende italiane, in special modo per le piccole e medie imprese (PMI) del settore IT che trattano dati personali dei propri clienti.

Un contesto normativo in piena evoluzione

Non si tratta di un tema solo teorico o consolidato da anni: in Italia la Direttiva NIS2 è stata recepita con il D.Lgs. 4 settembre 2024, n. 138, pubblicato in Gazzetta Ufficiale il 1° ottobre 2024 ed entrato in vigore il 16 ottobre 2024, che affida all'Agenzia per la Cybersicurezza Nazionale (ACN) il ruolo di autorità competente. Da gennaio 2025 i soggetti potenzialmente coinvolti sono tenuti a registrarsi entro il 28 febbraio di ogni anno sulla piattaforma dedicata dell'ACN, e l'attuazione del decreto sta procedendo per fasi successive ancora in corso. Sto quindi trattando un argomento su cui il quadro normativo si sta letteralmente definendo negli stessi mesi in cui scrivo questo elaborato, il che rende necessaria una lettura critica delle fonti piuttosto che il semplice richiamo a normative ormai stabilizzate.

Un dettaglio che ho ritenuto utile approfondire riguarda proprio l'ambito di applicazione soggettivo della norma: la NIS2 si applica in via diretta ai soggetti che superano contemporaneamente due soglie dimensionali (più di 50 dipendenti e oltre 10 milioni di euro di fatturato o totale di bilancio annuo) operanti in settori ad alta criticità. Molte PMI italiane di medie dimensioni, come ad esempio una software-house con una quarantina di dipendenti, si collocano appena sotto tale soglia e non rientrerebbero quindi tra i soggetti direttamente obbligati. Questa situazione è comunque istruttiva: la NIS2 impone infatti requisiti di sicurezza della catena di fornitura ai soggetti regolati, che si ripercuotono a cascata anche sui fornitori più piccoli e non direttamente obbligati, tramite clausole contrattuali. Una PMI apparentemente esclusa dal perimetro diretto della norma potrebbe quindi trovarsi comunque a dover adeguare le proprie pratiche di sicurezza su richiesta di un cliente maggiore soggetto a NIS2, questa è una dinamica importante da evidenziare proprio perché riflette una situazione concreta in cui molte PMI italiane si trovano oggi.

I concetti fondamentali della valutazione del rischio

Prima di descrivere la metodologia applicata, è utile richiamare alcuni concetti fondamentali su cui si basa qualunque processo di risk assessment (questi termini ripresi dagli standard ISO/IEC 27005 e NIST SP 800-30):

- **Minaccia (threat):** la fonte potenziale di un evento dannoso (es. un attaccante, un errore umano, un guasto tecnico).
- **Vulnerabilità (vulnerability):** la debolezza di un asset che una minaccia può sfruttare per causare un danno (es. una password debole, un software non aggiornato).
- **Probabilità (likelihood):** la stima di quanto sia probabile che una minaccia sfrutti con successo una vulnerabilità in un dato periodo di tempo.
- **Impatto (impact):** la gravità delle conseguenze nel caso in cui l'evento si verifichi davvero.
- **Rischio inerente:** il livello di rischio calcolato prima dell'applicazione di qualunque controllo di mitigazione - è il punto di partenza dell'analisi.
- **Rischio residuo:** il livello di rischio che permane dopo aver applicato i controlli di mitigazione; per definizione non è mai pari a zero.
- **Risk appetite (propensione al rischio):** il livello di rischio residuo che un'organizzazione è disposta ad accettare senza ulteriori interventi, definito a monte dal management; è un concetto che non ho quantificato esplicitamente negli esempi applicativi (richiederebbe una decisione aziendale reale,

specifica per ogni organizzazione), ma che è importante citare perché è ciò che, in un contesto reale, determina quando un piano di trattamento del rischio possa dirsi concluso.

Un ulteriore principio che ritengo utile esplicitare è la categorizzazione del rischio per tipologia di asset: raggruppare gli scenari in base alla natura della risorsa coinvolta (infrastruttura tecnica, processi operativi quotidiani, fattore fisico-organizzativo) è una pratica raccomandata dagli stessi standard ISO/IEC 27005, perché permette di assegnare la responsabilità di ciascuna area a funzioni aziendali competenti e di individuare pattern di rischio che un elenco piatto e non categorizzato difficilmente farebbe emergere. Riprendo concretamente questo principio al paragrafo 3.4, dove propongo una suddivisione in categorie applicabile a qualunque organizzazione, invece di limitarmi a un elenco non strutturato.

Da un punto di vista teorico, il concetto centrale resta comunque che il rischio non è un valore assoluto ma il prodotto di due componenti indipendenti: probabilità e impatto, e che la sua gestione richiede un processo continuo (identificazione, analisi, valutazione, trattamento, monitoraggio) e non una valutazione una tantum: anche per questo il quadro normativo descritto sopra, in continua evoluzione, richiede che le aziende trattino la sicurezza informatica come un processo permanente, non come un adempimento da chiudere una volta per tutte.

Un ultimo aspetto teorico rilevante riguarda la differenza tra approccio qualitativo, semi-quantitativo e quantitativo alla valutazione del rischio. Un approccio puramente qualitativo (ad esempio classificare un rischio come «alto» o «basso» sulla base di un giudizio soggettivo) è rapido da applicare ma poco confrontabile tra scenari diversi. All'estremo opposto si colloca l'approccio quantitativo puro, che esprime il rischio in termini numerici precisi e continui, tipicamente monetari (ad esempio la perdita economica annua attesa), calcolati a partire da dati storici, statistiche di frequenza degli eventi e modelli probabilistici: è l'approccio più rigoroso, ma anche il più oneroso da applicare correttamente, perché richiede dati che raramente un'organizzazione di piccole dimensioni possiede.

L'approccio semi-quantitativo adottato in questo elaborato si colloca a metà tra i due: utilizza scale numeriche discrete da 1 a 5 per Probabilità e Impatto, combinate in un punteggio da 1 a 25, secondo una logica a livelli ispirata all'impostazione suggerita da NIST SP 800-30 (che propone scale a cinque livelli, da Molto Basso a Molto Alto, lasciando alle organizzazioni la libertà di definire i propri valori numerici di riferimento) e coerente con la flessibilità metodologica lasciata da ISO/IEC 27005, che non impone una scala specifica ma richiede solo che ne venga adottata una coerente e documentata. Questo approccio rappresenta un compromesso equilibrato: mantiene la semplicità di applicazione tipica dei metodi qualitativi, ma introduce un livello minimo di oggettività e di confrontabilità tra scenari, evitando al contempo la complessità di modelli puramente quantitativi (come il FAIR, Factor Analysis of Information Risk) che richiederebbero dati storici di cui una PMI raramente dispone.

Per non restare su un piano puramente teorico, ho scelto di corredare la guida con esempi applicativi concreti (paragrafo 3.5), calcolati su scenari di rischio realistici e riferibili a un generico contesto aziendale IT; dalla gestione delle credenziali alla vulnerabilità di un componente software, fino all'uso non regolamentato di strumenti di intelligenza artificiale generativa. Ho preferito questo approccio a un unico caso di studio aziendale esteso, per mantenere il focus della guida sulla metodologia in sé, così come richiesto esplicitamente dalla traccia, piuttosto che su una narrazione aziendale che rischierebbe di distogliere l'attenzione dal vero obiettivo del documento.

Gli esempi presuppongono comunque, implicitamente, un contesto realistico: un'organizzazione che non dispone ancora di un ISMS (Sistema di Gestione della Sicurezza delle Informazioni) pienamente formalizzato, situazione comune a molte PMI italiane. Anche per questo la guida assume la funzione di punto di partenza pratico verso una gestione più strutturata della sicurezza, e non solo di descrizione teorica di una situazione già matura.

3.1 - Il fattore di rischio: cos'è e come si calcola

Il fattore di rischio è l'indicatore che permette di stimare quanto un evento avverso (un attacco informatico, un errore umano, un guasto tecnico) possa danneggiare un'organizzazione, tenendo conto sia di quanto sia probabile che accada sia di quanto sarebbero gravi le conseguenze. Il modello adottato in questa guida, coerente con gli standard ISO/IEC 27005 e NIST SP 800-30, esprime il rischio come prodotto di due componenti:

$$\text{Fattore di Rischio (R)} = \text{Probabilità (P)} \times \text{Impatto (I)}$$

Probabilità e Impatto sono espressi su una scala discreta da 1 a 5, per cui il punteggio R assume valori tra 1 e 25, classificati in quattro fasce di criticità (Basso 1-4, Medio 5-9, Alto 10-15, Critico 16-25). Questa formula non è rimasta solo teorica: l'ho implementata realmente all'interno della pagina web (paragrafo 3.7), dove alimenta un calcolatore interattivo che permette a chiunque di sperimentare concretamente la metodologia descritta in questa guida, senza dover fare i calcoli a mano. La tabella seguente riporta tutti i 25 possibili risultati del prodotto $P \times I$, colorati secondo la stessa logica delle quattro fasce di criticità - dal verde (rischio basso) al rosso (rischio critico):

P \ I	1	2	3	4	5
1	1	2	3	4	5
2	2	4	6	8	10
3	3	6	9	12	15
4	4	8	12	16	20
5	5	10	15	20	25

Figura 1 - matrice di riferimento Probabilità x Impatto: valore del prodotto R e fascia di criticità corrispondente per ciascuna combinazione

Anche la scelta cromatica non è casuale, i colori verde, giallo, arancione e rosso sono molto presenti nel mondo informatico: si ritrovano, ad esempio, nelle valutazioni di severità CVSS dove molti strumenti colorano allo stesso modo i punteggi di gravità delle CVE dal verde delle vulnerabilità minori al rosso di quelle critiche. Li troviamo spesso anche nelle dashboard di monitoraggio in modo che l'operatore possa capire subito a colpo d'occhio che priorità ha l'alert comparso favorendo così un intervento più rapido, seguendo le priorità stabilite.

3.2 - Minacce, vulnerabilità e il ruolo delle CVE

Per stimare correttamente Probabilità e Impatto è necessario prima distinguere due concetti che vengono spesso confusi: la minaccia (threat) è la fonte potenziale di un evento dannoso, un attaccante, un errore umano, un guasto tecnico; mentre la vulnerabilità (vulnerability) è la debolezza specifica di un sistema che una minaccia può sfruttare per causare un danno. Una minaccia senza una vulnerabilità da sfruttare resta un rischio teorico; una vulnerabilità che nessuna minaccia conosce o sfrutta genera comunque un'esposizione, ma con probabilità più bassa.

Le vulnerabilità del software non sono un'ipotesi astratta: la maggior parte di esse è documentata pubblicamente attraverso le CVE, un identificativo univoco assegnato a ogni vulnerabilità nota e catalogato nel NVD (National Vulnerability Database) gestito dal NIST statunitense. Ogni CVE è accompagnata da un punteggio di gravità secondo lo standard CVSS (Common Vulnerability Scoring System), che stima quanto sarebbe dannoso un eventuale sfruttamento. Conoscere le CVE che riguardano i propri sistemi: sistema operativo, librerie, framework, dipendenze software è il presupposto pratico per stimare in modo realistico sia la Probabilità (una CVE con exploit pubblico disponibile ha probabilità di sfruttamento molto più alta di una nota solo in teoria) sia l'Impatto (il punteggio CVSS indica direttamente quanto grave sarebbe la compromissione). Da qui discende un principio centrale in questa guida: una valutazione del rischio è affidabile solo quanto lo è la conoscenza del proprio perimetro. Per «perimetro» intendo l'inventario completo e aggiornato degli asset aziendali (dispositivi, applicazioni, versioni software in uso, servizi esposti) e delle loro obsolescenze cioè quali componenti non ricevono più aggiornamenti di sicurezza o eseguono versioni note per contenere vulnerabilità non risolte. Un'organizzazione che non sa con precisione quali sistemi possiede e il loro stato di aggiornamento non può, per definizione, stimare correttamente né la probabilità né l'impatto dei propri rischi. Questo è anche il motivo per cui un inventario degli asset (spesso gestito tramite una CMDB, Configuration Management Database) è considerato dagli standard ISO/IEC 27001-27005 un prerequisito, non un'attività accessoria, della gestione del rischio.

3.3 - Come si riduce il rischio: agire sulla probabilità o sull'impatto

Un principio fondamentale presente all'interno di questa guida, perché spesso viene dato per scontato senza spiegarne il meccanismo, è che qualunque misura di mitigazione efficace deve necessariamente abbassare almeno uno dei due valori da cui il rischio è composto (la Probabilità o l'Impatto) perché è solo dalla loro combinazione che deriva il fattore di rischio complessivo. Una misura che non incide su nessuno dei due, per quanto ben intenzionata, non riduce il rischio calcolato. Nella grande maggioranza dei casi pratici, i controlli di sicurezza agiscono riducendo la Probabilità: rendono un evento meno facile da verificarsi, senza cambiare la gravità delle conseguenze qualora dovesse accadere comunque. È il caso, ad esempio, dell'autenticazione a più fattori sugli account aziendali: non riduce il danno potenziale di un accesso non autorizzato ai dati, ma riduce nettamente la probabilità che un attaccante riesca ad autenticarsi anche disponendo di una password sottratta. Lo stesso vale per la formazione del proprio personale contro il phishing, per il controllo degli accessi fisici agli uffici, o per l'adozione di policy che regolano l'uso di strumenti di intelligenza artificiale generativa (il cosiddetto «Shadow AI»): in tutti questi casi il controllo rende l'evento meno probabile, non meno grave se accadesse comunque.

Esiste però una seconda famiglia di controlli che agisce sull'Impatto, ed è altrettanto importante non trascurarla: la remediation delle vulnerabilità note (patch management) è l'esempio più diretto. Quando

un componente software presenta una CVE nota con un punteggio CVSS elevato, magari perché consentirebbe l'esecuzione di codice da remoto o l'accesso completo al sistema, applicare la patch che la risolve non si limita a rendere l'attacco meno probabile: elimina concretamente la possibilità che quello specifico scenario di compromissione grave si realizzi, abbassando quindi il tetto massimo di danno ottenibile attraverso quella vulnerabilità. Anche misure come la segmentazione di rete, la cifratura dei dati a riposo o i backup testati regolarmente agiscono prevalentemente sull'Impatto: non impediscono che un incidente accada, ma ne limitano le conseguenze quando accade. Distinguere su quale dei due fattori agisce un controllo non serve come esercizio accademico: aiuta a costruire un piano di trattamento del rischio bilanciato, che non si limiti ad accumulare controlli dello stesso tipo (tipicamente quelli preventivi, più intuitivi da proporre) trascurando la capacità dell'organizzazione di limitare il danno quando, nonostante tutto, un evento avverso si dovesse verificare.

3.4 - Categorizzare i rischi

Un ultimo elemento metodologico prima di passare agli esempi applicativi è quello della categorizzazione del rischio: per essere utile in un contesto reale, un elenco di rischi non dovrebbe restare una lista piatta e disordinata. Raggruppare gli scenari individuati per tipologia di asset coinvolto è una pratica raccomandata dagli stessi standard ISO/IEC 27005, perché permette di assegnare la responsabilità di ciascuna area, di individuare pattern ricorrenti che un elenco non categorizzato difficilmente farebbe emergere, e di redigere un report finale molto più leggibile per chi deve prendere decisioni. Nella pratica, è utile distinguere almeno tre macrocategorie:

- **Rischi core e dati:** rischi che coinvolgono direttamente i sistemi critici e i dati trattati dall'organizzazione, database, applicazioni core, repository di codice sorgente. Sono tipicamente i rischi con l'impatto potenziale più alto.
- **Rischi infrastrutturali:** rischi legati alla gestione tecnica quotidiana dei sistemi, patch management, configurazione di rete, gestione delle credenziali, backup. Sono spesso i più numerosi e quelli su cui incide più direttamente la disciplina operativa del reparto IT.
- **Rischi fisici e organizzativi:** rischi legati al comportamento delle persone e alla sicurezza fisica degli ambienti, controllo degli accessi, formazione del personale, gestione dei dispositivi. Sono i rischi in cui la tecnologia da sola offre il minor margine di riduzione, perché il fattore umano resta comunque coinvolto.

Questa categorizzazione, oltre a strutturare meglio l'analisi, è coerente con il principio esposto al paragrafo precedente: le tre categorie tendono a rispondere in modo diverso al tipo di mitigazione più efficace; i rischi core e dati beneficiano spesso di controlli che riducono l'Impatto (segmentazione, cifratura, patch delle CVE più gravi), mentre i rischi infrastrutturali e quelli fisico-organizzativi sono più spesso trattabili riducendo la Probabilità attraverso policy, formazione e controlli procedurali.

3.5 - Esempi applicativi: rischio prima e dopo la mitigazione

Per rendere concreti i concetti esposti finora, riporto quattro esempi rappresentativi: tre in cui il controllo di mitigazione agisce principalmente sulla Probabilità e uno (la gestione di una vulnerabilità nota) in cui agisce principalmente sull'Impatto, così da mostrare visivamente come cambia il fattore di rischio prima e dopo l'applicazione della contromisura:

Rischio	Scenario	P	I	R	Fascia	Mitigazione	P'	I'	R'	Fascia	Agisce su
Gestione degli account	Credenziali deboli, assenza di autenticazione a più fattori	4	4	16	Critico	MFA obbligatoria + password policy robusta	1	4	4	Basso	Probabilità
Accesso fisico agli uffici	Badge prestato o clonato (tailgating)	3	3	9	Medio	Badge con doppio fattore + policy anti-tailgating	2	3	6	Medio	Probabilità
Uso di IA generativa (Shadow AI)	Invio di dati aziendali a chatbot pubblici non autorizzati	3	4	12	Alto	Policy sull'uso dell'IA + strumenti aziendali approvati	2	3	6	Medio	Probabilità
Vulnerabilità software nota (CVE)	Componente con CVE pubblica non aggiornato, potenzialmente sfruttabile per compromissione totale	3	5	15	Alto	Applicazione della patch che risolve la CVE	2	2	4	Basso	Impatto

Tabella 1 - quattro esempi di rischio informatico con relativa mitigazione: valori prima (P, I, R) e dopo (P', I', R') l'applicazione del controllo

Si nota come nei primi due casi il valore di Impatto (I) resti invariato dopo la mitigazione mentre cambia sensibilmente la Probabilità. Nel terzo esempio (Shadow AI) la mitigazione riduce leggermente anche l'Impatto oltre alla Probabilità: adottare una policy con strumenti approvati non si limita a rendere l'evento meno probabile, ma ne contiene anche le conseguenze, perché i dati restano circoscritti a strumenti sotto il controllo dell'azienda invece che dispersi su servizi esterni non tracciabili. Nel quarto esempio, quello della vulnerabilità nota (CVE), la mitigazione agisce su entrambe le componenti: applicare la patch riduce sia la Probabilità, perché quello specifico exploit non è più utilizzabile, sia l'Impatto, perché anche un nuovo tentativo di attacco non potrebbe più sfruttare quella falla per ottenere una compromissione totale del sistema. Va però precisato che questo effetto non è permanente: dura finché non viene scoperta e resa pubblica una nuova vulnerabilità analoga su quello stesso asset, motivo per cui il patch management non è un'attività da fare una tantum ma un processo continuo nel tempo.

3.6 - Best practice di sicurezza

Chiudo la parte teorica con un elenco di best practice generalmente riconosciute nel settore, richiamate anche negli esempi del paragrafo precedente, utili come punto di partenza per chiunque debba impostare un primo piano di trattamento del rischio:

- **Gestione di password e account:** lunghezza minima di 12-14 caratteri, uso di caratteri speciali, divieto di riutilizzo delle ultime password, e soprattutto autenticazione a più fattori (MFA) su tutti gli account con accesso a sistemi o dati sensibili: da sola, la MFA riduce drasticamente l'efficacia del furto di credenziali.
- **Patch management:** l'inventario aggiornato di asset e vulnerabilità (paragrafo 3.2) deve tradursi in un processo periodico e documentato di applicazione delle patch di sicurezza, con priorità alle CVE con punteggio CVSS più alto e a quelle con exploit pubblicamente disponibile.
- **Monitoraggio attivo e passivo:** sistemi di monitoraggio attivo (che intervengono in tempo reale, come un IPS, Intrusion Prevention System, che blocca automaticamente il traffico sospetto) e sistemi di monitoraggio passivo (che osservano e segnalano senza intervenire direttamente, come un IDS, Intrusion Detection System, o un semplice sistema di log centralizzato) sono entrambi necessari: il primo riduce la finestra temporale di esposizione durante un attacco in corso, il secondo garantisce la

tracciabilità necessaria per analizzare un incidente dopo che è avvenuto.

- **Consapevolezza del personale:** formazione periodica del personale e simulazioni di phishing tramite campagne ad hoc, perché una parte rilevante dei rischi qui descritti ha una componente umana che nessun controllo puramente tecnico può azzerare del tutto.
- **Segmentazione e privilegio minimo:** la segmentazione della rete e dei permessi (secondo il principio del privilegio minimo) limita la capacità di movimento di un utente malevolo che sia comunque riuscito a ottenere un accesso iniziale, riducendo l'Impatto complessivo anche quando la Probabilità non può essere azzerata.

3.7 - Sviluppo della pagina web

La guida teorica sopra descritta è resa fruibile online tramite una pagina web sviluppata come un unico file HTML autonomo (index.html), con CSS e JavaScript interamente incorporati al suo interno, senza alcuna dipendenza da file esterni o framework di terze parti. Questa scelta garantisce portabilità: il file può essere aperto ovunque, anche senza connessione e senza un server web, con un semplice doppio clic.

Il dimensionamento della pagina è affidato a una media query che, sotto i 620px di larghezza, riorganizza il layout da multi-colonna a colonna singola e porta i pulsanti a larghezza piena per facilitare il tocco su smartphone:

```
298     @media (max-width: 620px) {
299         .wrap { padding: 1.6rem 0 3rem; }
300         .hero { padding: 1.8rem 1.3rem 1.7rem; }
301         .section { padding: 1.4rem 1.3rem; }
302         .grid-2 { grid-template-columns: 1fr; gap: 1.8rem; }
303         .qr-block { order: -1; }
304         .actions { flex-direction: column; }
305         .btn { width: 100%; justify-content: center; }
306         .calc-grid { grid-template-columns: 1fr; }
307     }
308
```

Estratto 1 - regola responsive principale (righe 298-308 di index.html)

L'intestazione della pagina richiama i riferimenti normativi principali (GDPR, NIS2, ISO/IEC 27005) e contiene i due pulsanti di azione richiesti dalla traccia: il primo avvia il download diretto del documento PDF tramite l'attributo HTML «download», il secondo («Apri da smartphone») è un semplice link ancora che porta alla sezione con il QR code, utile su desktop per chi vuole poi inquadrarlo da un altro dispositivo:

```

322     <header class="hero">
323         <div class="eyebrow">Guida normativa &middot; Sicurezza informatica</div>
324         <h1>Il Calcolo del Fattore di Rischio Informatico</h1>
325         <p class="lede">
326             Guida chiara e dettagliata al calcolo del fattore di rischio informatico, in
327             conformat&agrave; alle normative europee vigenti in materia di protezione dei dati
328             e sicurezza delle informazioni.
329         </p>
330
331         <div class="badge-row">
332             <span class="risk-chip"><span class="swatch high"></span>Regolamento (UE) 2016/679 &mdash; <b>GDPR</b></span>
333             <span class="risk-chip"><span class="swatch high"></span>Direttiva (UE) 2022/2555 &mdash; <b>NIS2</b></span>
334             <span class="risk-chip"><span class="swatch high"></span>ISO/IEC 27005 &mdash; <b>Risk Management</b></span>
335         </div>
336
337         <div class="actions">
338             <a class="btn btn-primary" href="fattore_rischio_informatico.pdf" download>
339                 &darr; Scarica il documento (PDF)
340             </a>
341             <a class="btn btn-ghost" href="#qr">
342                 Apri da smartphone
343             </a>
344         </div>
345
346     </header>

```

Estratto 2 - intestazione, badge normativi e pulsanti di download/navigazione (righe 322-346 di index.html)

3.8 - Calcolatore interattivo e QR code

Oltre a quanto richiesto dalla traccia, ho scelto di aggiungere un calcolatore interattivo: l'utente seleziona Probabilità e Impatto da due menu a tendina, vede comparire dinamicamente la descrizione testuale del livello selezionato (le stesse descrizioni approfondite riportate nel paragrafo 3.1), e ottiene immediatamente il valore di R e la fascia di criticità corrispondente. Non è un elemento richiesto esplicitamente, ma l'ho ritenuto coerente con lo spirito della traccia (il calcolo del fattore di rischio) e utile per rendere la pagina non solo un punto di accesso statico al PDF, ma uno strumento che permette di sperimentare concretamente la metodologia descritta nel documento.

```

359 <section class="section" id="calcolatore">
360 <h2><span class="num">02</span> Calcola il tuo fattore di rischio</h2>
361 <p style="color:var(--muted); font-size:0.92rem; margin-bottom:1.2rem;">
362     Seleziona Probabilit  e Impatto (scala 1&ndash;5) per calcolare in tempo reale
363     il fattore di rischio  $R = P \times I$  e la relativa fascia di criticit . La
364     descrizione di ogni livello si aggiorna automaticamente in base alla selezione.
365 </p>
366 <div class="calc-grid">
367     <div class="calc-field">
368         <label for="selProbabilita">Probabilit  (P)</label>
369         <select id="selProbabilita">
370             <option value="1">1 &mdash; Raro</option>
371             <option value="2">2 &mdash; Improbabile</option>
372             <option value="3" selected>3 &mdash; Possibile</option>
373             <option value="4">4 &mdash; Probabile</option>
374             <option value="5">5 &mdash; Molto probabile</option>
375         </select>
376     </div>
377     <div class="calc-field">
378         <label for="selImpatto">Impatto (I)</label>
379         <select id="selImpatto">
380             <option value="1">1 &mdash; Trascurabile</option>
381             <option value="2">2 &mdash; Minore</option>
382             <option value="3">3 &mdash; Moderato</option>
383             <option value="4" selected>4 &mdash; Grave</option>
384             <option value="5">5 &mdash; Critico</option>
385         </select>
386     </div>
387 </div>
388
389 <div class="calc-grid" style="margin-top:-0.3rem;">
390     <div class="level-desc" id="descProbabilita"></div>
391     <div class="level-desc" id="descImpatto"></div>
392 </div>
393
394 <button class="btn btn-primary" id="btnCalcola" style="width:100%; justify-content:center;">
395     Calcola fattore di rischio
396 </button>
397 <div class="calc-result" id="calcResult">
398     <span>Fattore di rischio (R):</span>
399     <span class="r-value" id="rValue">&mdash;</span>
400     <span class="r-fascia" id="rFascia">&mdash;</span>
401 </div>
402 </section>

```

Estratto 3 - markup del calcolatore interattivo, con le tendine di selezione e i contenitori per le descrizioni dinamiche (righe 359-402 di index.html)

La logica di calcolo   la stessa formula descritta al paragrafo 3.1, questa volta implementata in JavaScript: una struttura if/else assegna la fascia di criticit  in base al valore di R, esattamente secondo le soglie della matrice di Figura 1:

```

482     function calcolaFattoreRischio(probabilita, impatto) {
483         const r = probabilita * impatto;
484         let fascia;
485
486         if (r <= 4) {
487             fascia = "Basso";
488         } else if (r <= 9) {
489             fascia = "Medio";
490         } else if (r <= 15) {
491             fascia = "Alto";
492         } else {
493             fascia = "Critico";
494         }
495
496         return { valore: r, fascia: fascia };
497     }

```

Estratto 4 - funzione calcolaFattoreRischio, con la struttura if/else per la classificazione in fasce (righe 482-497 di index.html)

Le due funzioni seguenti gestiscono rispettivamente la mappatura tra fascia testuale e classe CSS (per colorare il risultato in modo coerente con la matrice) e l'aggiornamento delle descrizioni dinamiche di Probabilità e Impatto ogni volta che l'utente cambia una delle due selezioni:

```

499     function classeFascia(fascia) {
500         const mappa = {
501             "Basso": "fascia-basso",
502             "Medio": "fascia-medio",
503             "Alto": "fascia-alto",
504             "Critico": "fascia-critico"
505         };
506         return mappa[fascia] || "";
507     }
508
509     function aggiornaDescrizioni() {
510         const p = parseInt(document.getElementById("selProbabilita").value, 10);
511         const i = parseInt(document.getElementById("selImpatto").value, 10);
512
513         document.getElementById("descProbabilita").innerHTML = DESCRIZIONI_PROBABILITA[p];
514         document.getElementById("descImpatto").innerHTML = DESCRIZIONI_IMPATTO[i];
515     }

```

Estratto 5 - gestione della fascia di criticità e aggiornamento dinamico delle descrizioni (righe 499-515 di index.html)

Il QR code, infine, non viene generato lato client: è stato prodotto offline con uno strumento di supporto esterno alla pagina e poi incorporato in index.html come immagine codificata in base64 direttamente nell'attributo src di un tag , evitando così una richiesta di rete separata per caricare il file immagine. Tutto il codice qui descritto: HTML, CSS e JavaScript, si trova quindi in un unico file, reso disponibile per intero nel repository GitHub già indicato nel paragrafo “Risorse e strumenti utilizzati”

Campi di applicazione

(Descrivere gli ambiti di applicazione dell'elaborato progettuale e i vantaggi derivanti della sua applicazione):

Pur essendo presentata attraverso esempi applicativi specifici, la metodologia e gli strumenti realizzati sono trasferibili a qualunque contesto organizzativo, con adattamenti limitati.

- **Altre PMI del settore IT o non IT:** la matrice $R = P \times I$ e il ciclo di trattamento ISO/IEC 27005 sono applicabili a qualsiasi PMI, indipendentemente dal settore, purché si ridefiniscano gli asset e gli scenari di minaccia specifici del nuovo contesto (il concetto di perimetro a cui facevamo riferimento).
- **Supporto alla certificazione ISO/IEC 27001:** la struttura del documento (introduzione normativa, metodologia, caso applicativo, piano di trattamento) può essere riutilizzata come base per la documentazione richiesta da un ISMS conforme a ISO/IEC 27001, ad esempio nella fase di definizione del risk assesment.
- **Distribuzione di documentazione aziendale:** la pagina web con QR code è un pattern riutilizzabile per qualunque documento aziendale che debba essere distribuito e consultato facilmente da dispositivi mobili (policy interne, manuali, informative privacy).
- **Supporto all'audit interno e all'assegnazione di responsabilità:** la scomposizione del rischio per categoria (infrastruttura, quotidianità operativa, ambito fisico-organizzativo) è un modello riutilizzabile anche in contesti di audit interno, per assegnare la responsabilità di ciascuna area a funzioni aziendali diverse coerentemente con le rispettive competenze.

Valutazione dei risultati

(Descrivere le potenzialità e i limiti ai quali i risultati dell'elaborato sono potenzialmente esposti):

Concludo l'elaborato con una valutazione di quanto realizzato, comprensiva dei limiti riscontrati e dei possibili sviluppi futuri. Dopo la pubblicazione della pagina su GitHub Pages, ho potuto anche condurre una verifica con strumenti di audit automatico, i cui risultati sono riportati più sotto insieme al resto della valutazione.

Potenzialità

- **Solidità metodologica:** la metodologia si basa su standard riconosciuti (ISO/IEC 27005, NIST SP 800-30) e non su una scala inventata, il che la rende difendibile e riutilizzabile in contesti reali.
- **Ampiezza dei contenuti:** la guida non si limita a definizioni astratte ma include il ruolo delle CVE, la conoscenza del perimetro aziendale e best practice concrete (password policy, monitoraggio attivo/passivo, patch management), oltre a esempi applicativi che coprono sia rischi comportamentali/organizzativi (Shadow AI, accesso fisico) sia rischi tecnici (vulnerabilità software note)
- **Consapevolezza del limite dei controlli:** la distinzione tra controlli che agiscono sulla Probabilità e controlli che agiscono sull'Impatto, esplicitata nella Tabella 1 del paragrafo 3.5, e un livello di analisi che va oltre la semplice elencazione di contromisure generiche.
- **Verifica pratica, non solo teorica:** la pagina web è stata verificata sia su viewport desktop sia mobile, con attenzione a criteri di accessibilità fin dalla fase di sviluppo, e successivamente anche con strumenti di audit automatico dopo la pubblicazione online.

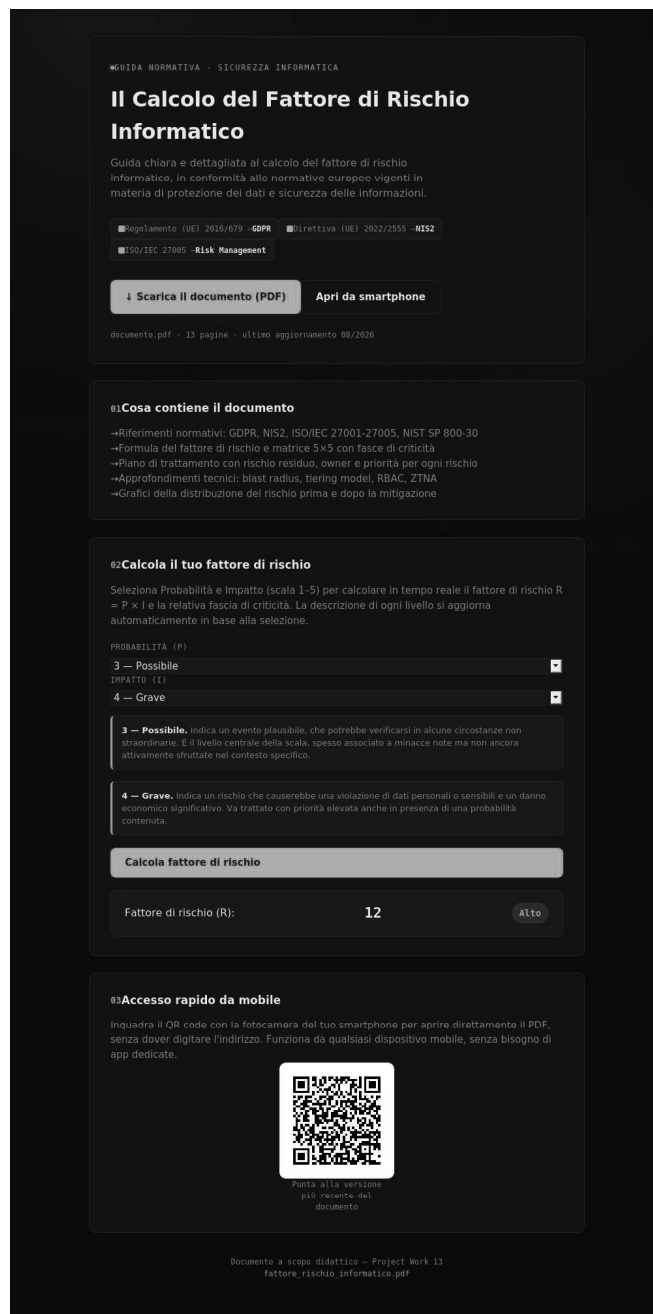


Figura 1 - resa attuale della pagina su viewport desktop (1000px)



Figura 2 - resa attuale della pagina su viewport mobile (390px, porzione superiore)

Verifica con strumenti di audit automatico:

Dopo la pubblicazione della pagina su GitHub Pages, ho potuto eseguire una verifica con Lighthouse, lo strumento di audit automatico integrato in Chrome, sia in versione desktop sia in versione mobile (quest'ultima simula le condizioni di rete e di CPU tipiche di uno smartphone di fascia media, motivo per cui alcuni punteggi risultano naturalmente più bassi rispetto alla versione desktop).

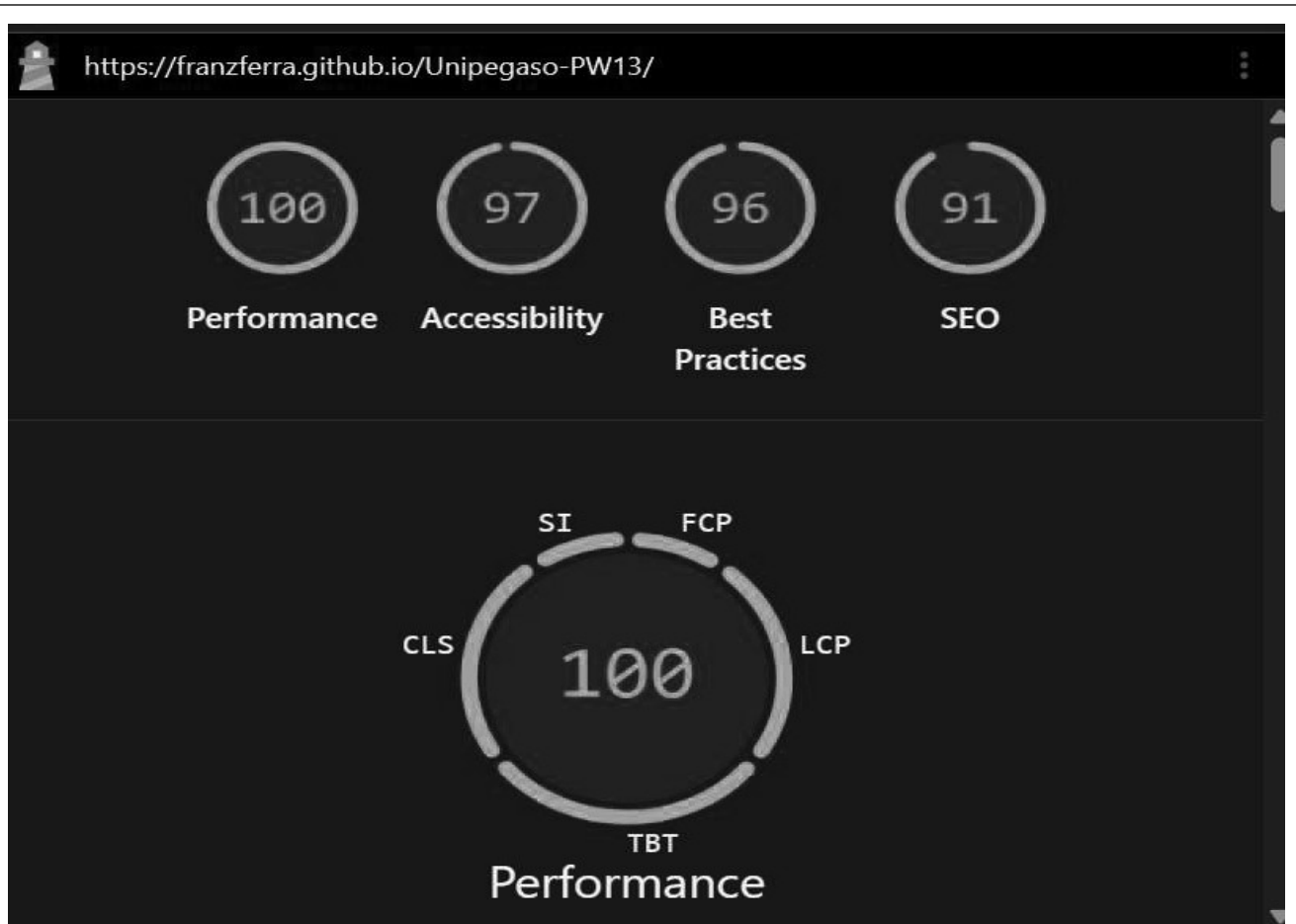


Figura 3 - report Lighthouse desktop: Performance 100, Accessibility 97, Best Practices 96, SEO 91

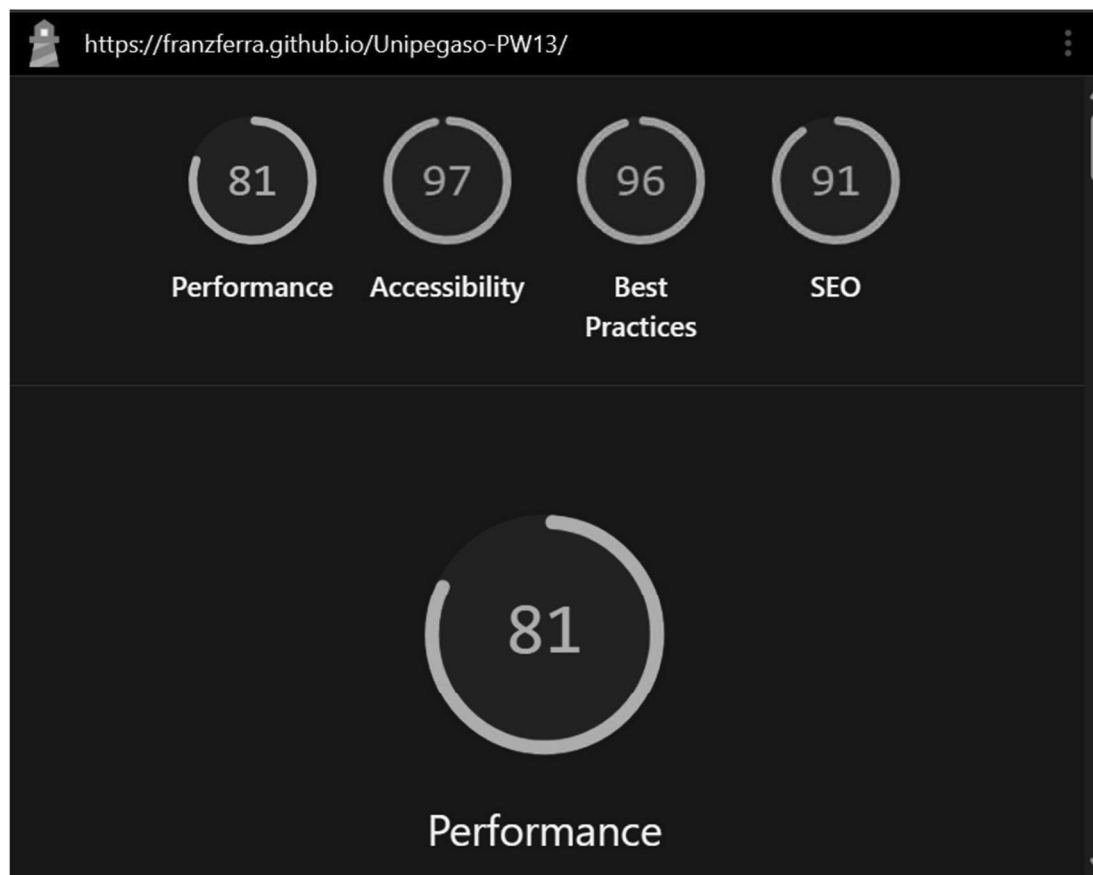


Figura 4 - report Lighthouse mobile: Performance 81, Accessibility 97, Best Practices 96, SEO 91

I risultati sono complessivamente solidi. Andando però a leggere il dettaglio di ogni singolo controllo, ho individuato con precisione la causa di ogni punteggio non pieno.

Sul fronte dell'accessibilità (97/100), l'unico controllo non superato segnala che il documento non racchiude il contenuto principale in un elemento main: la pagina usa correttamente header, section e footer, ma manca questo specifico tag semantico, utile a chi naviga con uno screen reader per saltare direttamente al contenuto senza dover attraversare tutta l'intestazione.

Sul fronte SEO (91/100), la causa è altrettanto puntuale: manca il tag meta description nell'intestazione della pagina, l'elemento che i motori di ricerca mostrano come anteprima testuale nei risultati di ricerca.

Per quanto riguarda Best Practices (96/100) e la parte di JavaScript segnalata come "inutilizzata" nel report Performance, ho verificato che entrambe le segnalazioni non riguardano il codice della pagina: il primo è un avviso generico del browser su una policy interna (permessi legati all'evento unload), il secondo proviene interamente da estensioni installate nel browser usato per il test (un'estensione per la gestione di PDF e un'altra estensione), non da script scritti nella pagina. Ho verificato questo punto controllando direttamente l'elenco dei file segnalati nel report, che risultano tutti provenienti da chrome-extension://, non dal dominio del sito.

Questa distinzione mi sembra importante: un audit automatico va sempre letto criticamente, perché può includere segnalazioni legate all'ambiente di test (estensioni del browser, policy di sistema) che non hanno nulla a che fare con la qualità del codice sviluppato.

Limiti:

- **Natura illustrativa degli esempi** - gli esempi applicativi presentati sono scenari plausibili costruiti a scopo didattico; i valori di Probabilità e Impatto sono stime ragionate ma non derivano da dati storici reali di incidenti, che in un contesto aziendale reale andrebbero raccolti nel tempo per calibrare la scala con maggiore precisione.
- **Margini minori individuati dall'audit** - come emerso dalla verifica Lighthouse, restano due correttivi facilmente applicabili non ancora implementati: l'aggiunta di un elemento main per la struttura semantica e di un tag meta description per la SEO.

Possibili sviluppi futuri:

- **Integrazione con database CVE** - integrare l'inventario degli asset con query automatiche a database pubblici di vulnerabilità note (CVE, tramite le API del NVD), per affiancare alla stima qualitativa un dato quantitativo verificabile sulle vulnerabilità effettivamente presenti nei componenti software utilizzati.
- **Impatto multidimensionale** - suddividere il valore di Impatto in sottocategorie (economico, reputazionale, di conformità normativa, operativo) invece di un unico valore aggregato, per un'analisi ancora più granulare.
- **Modularizzazione del codice** - l'attuale scelta di mantenere HTML, CSS e JavaScript in un unico file index.html è stata deliberata per semplicità e portabilità in questo contesto didattico, ma per un progetto di dimensioni maggiori sarebbe consigliabile scorporare il file in moduli separati per funzione (markup, fogli di stile, script), così da poter lavorare su ciascuna parte in modo indipendente.
- **Applicazione dei correttivi minori** - risolvere i due margini individuati dall'audit Lighthouse (elemento main, meta description) ed eseguire una seconda verifica con axe DevTools come controllo incrociato, per ridurre ulteriormente il margine di errore della sola verifica manuale iniziale.